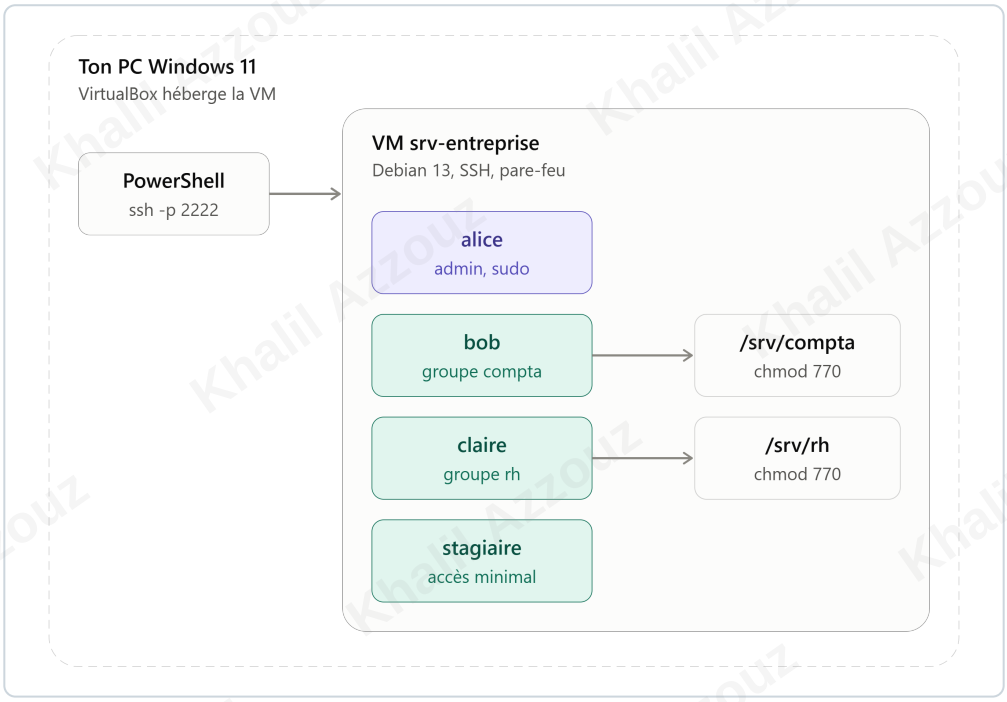
Linux Security Audit Tool

Rapport de construction du laboratoire

Serveur d'entreprise de test — Debian 13 sous VirtualBox



Projet d'apprentissage en cybersécurité

Auteur : Khalil Azzouz • Date : 18 octobre 2026

Hôte : Windows 11 • Invité : Debian 13 « Trixie »

Khalil Azzouz

Rapport de laboratoire

Ce document retrace, étape par étape, la construction d'un serveur Linux de test destiné à être audité par un script de sécurité maison. Il couvre l'installation de la machine virtuelle, la création des comptes et des dossiers d'une petite entreprise fictive, l'introduction volontaire de failles, et l'audit manuel qui valide que ces failles sont détectables.

> **Avertissement.** Toutes les manipulations sont réalisées dans une machine virtuelle isolée, sans exposition à internet. Les failles introduites volontairement ne doivent jamais l'être sur une machine réelle ou de production.

1. Sommaire

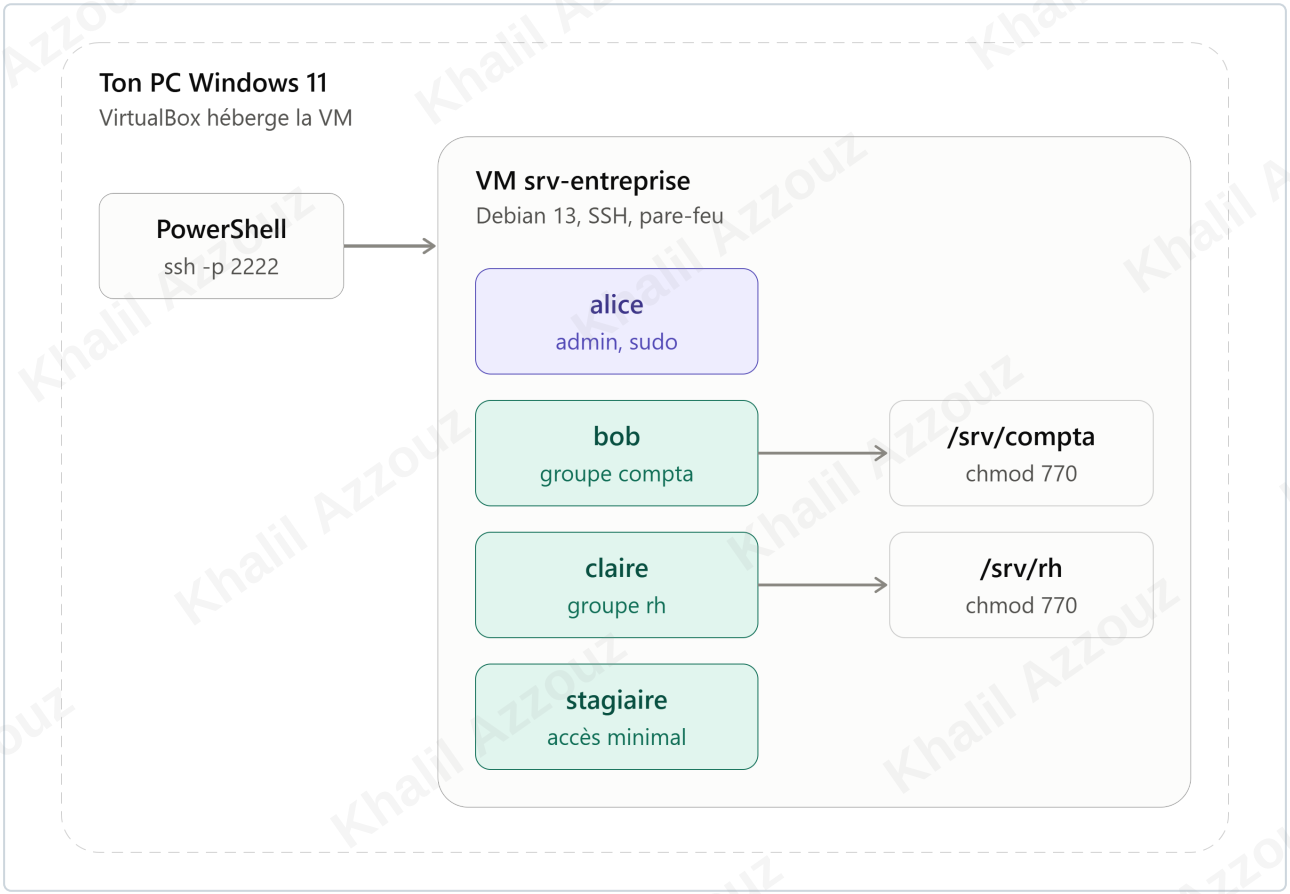
- 2. Concepts : VM, conteneur, et pourquoi ce laboratoire
- 3. Environnement et création de la VM
- 4. Installation de Debian
- 5. Durcissement initial : retrait de l'interface graphique
- 6. Accès distant par SSH
- 7. Utilisateurs et groupes de l'entreprise
- 8. Dossiers par service et permissions
- 9. Snapshots
- 10. Failles introduites volontairement
- 11. Audit manuel sur l'état vulnérable
- 12. Les contrôles du script et leur score
- 13. Le script audit.sh
- 14. Résultats : vulnerable vs propre

2. Concepts : VM, conteneur, et pourquoi ce laboratoire

Une **machine virtuelle (VM)** est un ordinateur complet simulé à l'intérieur d'un autre. Elle possède son propre noyau Linux et se comporte comme un vrai serveur : on peut y créer des utilisateurs, y configurer SSH et un pare-feu. C'est notre serveur d'entreprise de test.

Un **conteneur** (Docker) est plus léger : il partage le noyau de la machine hôte et ne contient que le strict minimum pour faire tourner une application. Il démarre en une seconde. On l'utilisera plus tard pour vérifier que le script d'audit fonctionne aussi dans un environnement minimal.

Auditer un système veut dire vérifier que chaque utilisateur n'a accès qu'à ce dont il a besoin, et qu'aucune porte n'est laissée ouverte. Pour tester un tel outil, il faut un serveur réaliste : d'où cette entreprise fictive avec une administratrice, un comptable, une personne aux ressources humaines et un stagiaire.

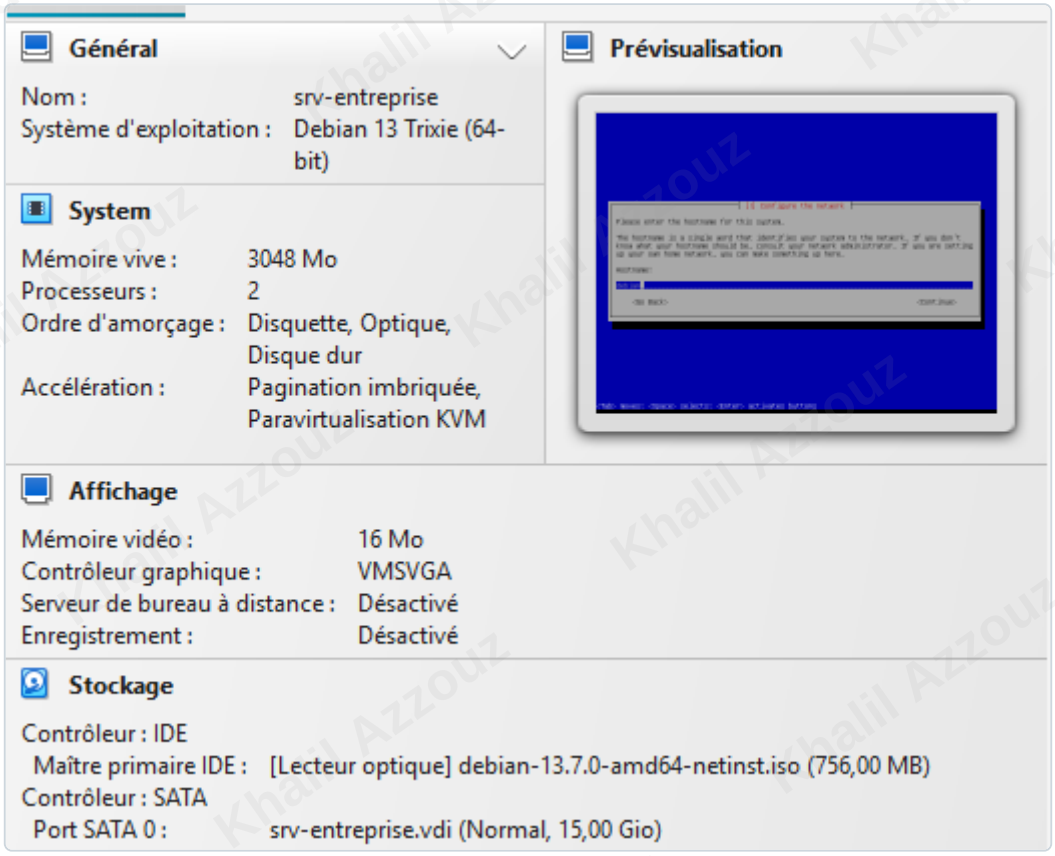


Architecture du laboratoire : PC Windows → VM Debian → utilisateurs et dossiers protégés.

3. Environnement et création de la VM

Élément	Valeur
Machine hôte	PC Windows 11, 32 Go de RAM
Hyperviseur	Oracle VirtualBox
OS invité	Debian 13 « Trixie » (64 bits), `debian-13.7.0-amd64-netinst.iso`
Ressources	2 CPU, 3048 Mo de RAM, disque de 15 Gio
Nom de la VM	`srv-entreprise`

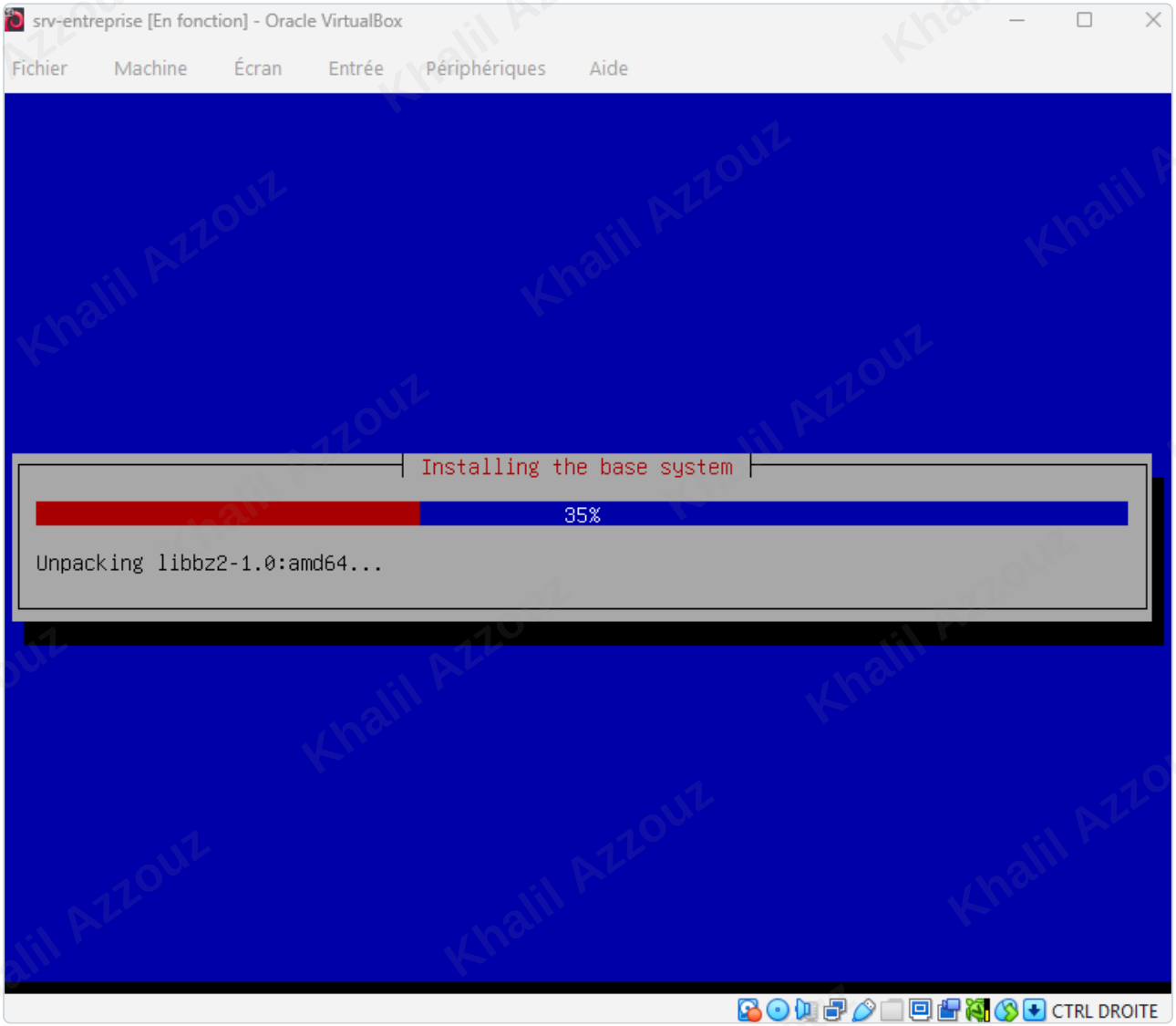
La VM est créée avec l'option **Skip Unattended Installation** cochée, afin d'installer Debian à la main et de maîtriser chaque choix (comptes, paquets).



Paramètres de la VM dans VirtualBox.

4. Installation de Debian

Écran	Choix	Pourquoi
Nom de machine	srv-entreprise	—
Mot de passe root	**laissé vide**	Debian désactive root et installe sudo : bonne pratique
Utilisateur	alice (mot de passe solide)	Compte administrateur via sudo
Partitionnement	Assisté, disque entier	Simple pour un labo
popularity-contest	Non	Un serveur n'envoie pas de statistiques dehors



Installation du système de base.

5. Durcissement initial : retrait de l'interface graphique

GNOME avait été installé par erreur. Un serveur n'a pas besoin d'interface graphique : moins de logiciels installés, c'est moins de surface d'attaque.

```
sudo apt purge -y task-gnome-desktop task-desktop gnome-core
sudo apt purge -y gdm3
sudo apt autoremove --purge -y
sudo systemctl set-default multi-user.target
```

```
alice@srv-entreprise:~$ sudo apt purge -y task-gnome-desktop task-desktop gdm gnome-core
[sudo] password for alice:
Package 'gdm' is not installed, so not removed
The following packages were automatically installed and are no longer required:
  baobab                    fonts-symbola           gnome-contacts          libatk-adaptor              libgtksourcevi
  bc                        geoclue-2.0             gnome-disk-utility      libcairomm-1.16-1           libgvnc-1.0-0
  cups                      gir1.2-geocodeglib-2.0  gnome-font-viewer       libcupsfilters1t64          libjavascriptc
  cups-browsed              gir1.2-json-1.0         gnome-logs              libedataserverui4-1.0-0t64  liblouisutdml-
  cups-client               gir1.2-rest-1.0         gnome-maps              libeditorconfig0            liblouisutdml-
  cups-core-drivers         gir1.2-shumate-1.0      gnome-snapshot          libfolks-eds26              liblouisutdml9
  cups-daemon               gir1.2-xdp-1.0          gnome-system-monitor    libfolks26                  libopengl0
  cups-filters              glycin-loaders          gnome-text-editor       libfontembed1t64            libpangomm-2.4
  cups-filters-core-drivers gnome-backgrounds       gnome-tour              libfreerdp-client3-3        libpoppler-cpp
  cups-ipp-utils            gnome-calculator        gnome-weather           libglibmm-2.68-1t64         libqpdf30
  cups-ppdc                 gnome-calendar          gstreamer1.0-gtk4       libglu1-mesa                libshumate-1.0
  cups-server-common        gnome-characters        gstreamer1.0-libcamera  libgtk-vnc-2.0-0            libshumate-com
  folks-common              gnome-clocks            gstreamer1.0-packagekit libgtkmm-4.0-0              libsigc++-3.0-
  fonts-noto-color-emoji    gnome-connections       gvfs-fuse               libgtksourceview-5-0        libspelling-1-
Use 'sudo apt autoremove' to remove them.

REMOVING:
  gnome*  gnome-core*  task-desktop*  task-gnome-desktop*

Summary:
  Upgrading: 0, Installing: 0, Removing: 4, Not Upgrading: 0
  Freed space: 49.2 kB

(Reading database ... 138828 files and directories currently installed.)
Removing gnome (1:48+2) ...
Removing task-gnome-desktop (3.81) ...
Removing gnome-core (1:48+2) ...
Removing task-desktop (3.81) ...
alice@srv-entreprise:~$
```

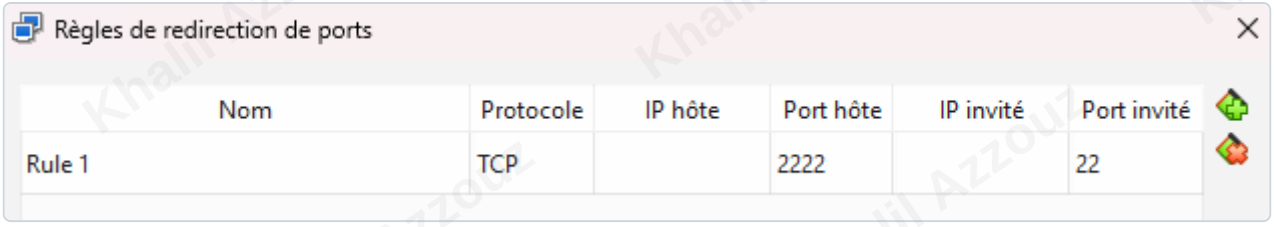
Suppression des paquets du bureau GNOME.

```
alice@srv-entreprise:~$ sudo apt purge -y gdm3
[sudo] password for alice:
Package 'gdm3' is not installed, so not removed
The following packages were automatically installed and are no longer required:
  espeak-ng-data   libaudio2      liblouis-data  libspeechd-module0  libxres1       python3-louis         sound-icons                    xbrlapi
  gir1.2-wnck-3.0  libbrlapi0.8   liblouis20     libspeechd2         orca           python3-psutil        speech-dispatcher              xkbset
  libao-common     libdotconf0    libpcaudio0    libwnck-3-0         perl-tk        python3-setproctitle  speech-dispatcher-audio-plugins
  libao4           libespeak-ng1  libsonic0      libwnck-3-common    python3-brlapi python3-speechd       speech-dispatcher-espeak-ng
Use 'sudo apt autoremove' to remove them.
```

gdm3 n'était déjà plus installé ; apt propose de retirer les dépendances devenues inutiles.

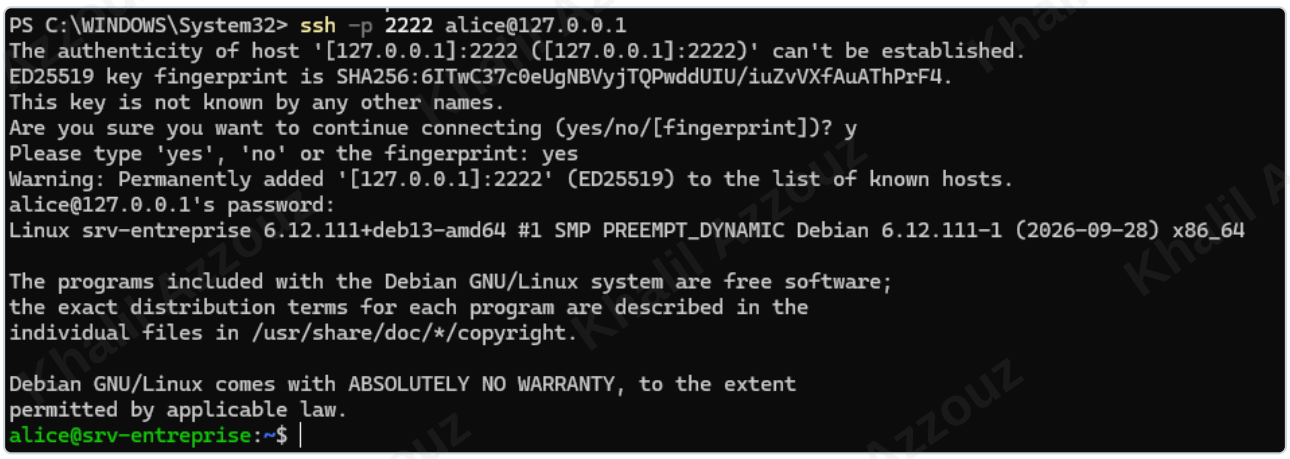
6. Accès distant par SSH

Une règle de redirection de port dans VirtualBox relie le port 2222 de Windows au port 22 de la VM, ce qui permet de se connecter en SSH depuis PowerShell.



Redirection de port 2222 (hôte) → 22 (invité).

```
ssh -p 2222 alice@127.0.0.1
```

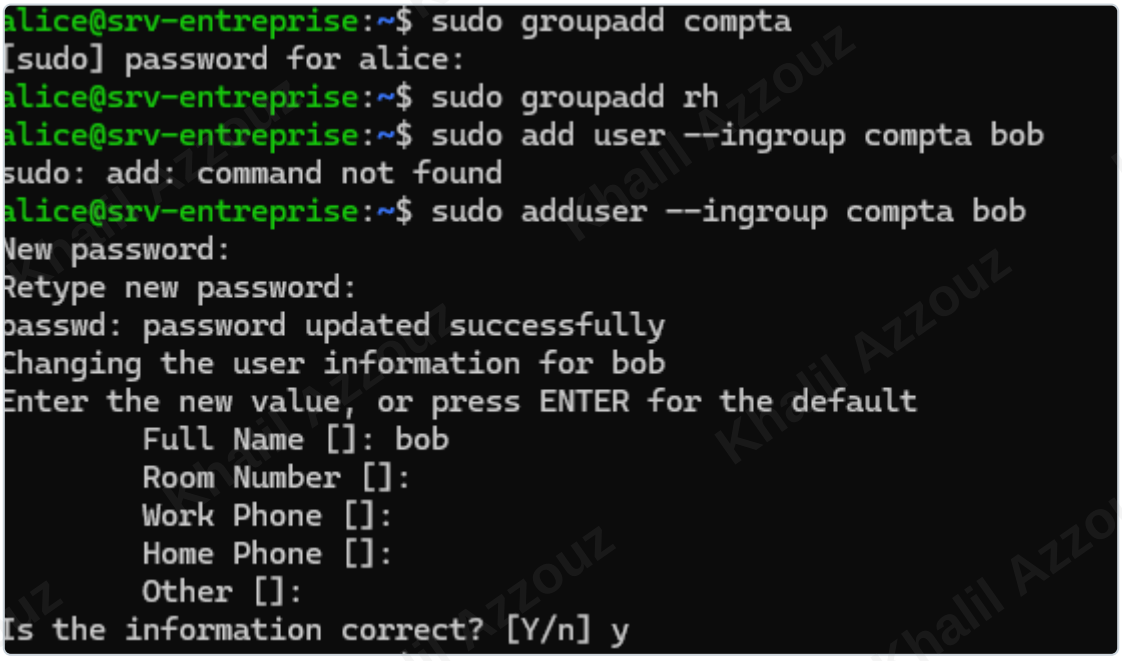


Première connexion SSH réussie. La confirmation de l'empreinte est normale.

7. Utilisateurs et groupes de l'entreprise

```
sudo groupadd compta
sudo groupadd rh
sudo adduser --ingroup compta bob
sudo adduser --ingroup rh claire
sudo adduser stagiaire
```

Utilisateur	Groupe	Rôle
alice	sudo	Administratrice système
bob	compta	Comptable
claire	rh	Ressources humaines
stagiaire	stagiaire	Accès minimal



Création du groupe compta et de l'utilisateur bob.

```
alice@srv-entreprise:~$ sudo adduser --ingroup rh claire
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for claire
Enter the new value, or press ENTER for the default
        Full Name []: claire
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n]
alice@srv-entreprise:~$ sudo adduser stagiaire
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for stagiaire
Enter the new value, or press ENTER for the default
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
```

Création de claire (rh) et de stagiaire.

```
alice@srv-entreprise:~$ getent passwd bob stagiaire claire
bob:x:1001:1001:bob,,,:/home/bob:/bin/bash
stagiaire:x:1003:1003:,,,:/home/stagiaire:/bin/bash
claire:x:1002:1002:claire,,,:/home/claire:/bin/bash
```

Vérification : les trois comptes ont des UID ≥ 1000 (comptes humains).

8. Dossiers par service et permissions

Chaque service reçoit son dossier, réservé à son groupe. Le `chmod 770` donne tous les droits au propriétaire et au groupe, et **aucun** aux autres.

```
sudo mkdir -p /srv/compta /srv/rh
sudo chown root:compta /srv/compta
sudo chown root:rh /srv/rh
sudo chmod 770 /srv/compta /srv/rh
```

```
alice@srv-entreprise:~$ sudo mkdir -p /srv/compta /srv/rh
alice@srv-entreprise:~$ sudo chown root:compta /srv/compta
alice@srv-entreprise:~$ sudo chown root:rh /srv/rh
alice@srv-entreprise:~$ ls -la /srv/rh
total 8
drwxr-xr-x 2 root rh   4096 Oct 18 11:06 .
drwxr-xr-x 5 root root 4096 Oct 18 11:06 ..
alice@srv-entreprise:~$ ls -la /srv/compta
total 8
drwxr-xr-x 2 root compta 4096 Oct 18 11:06 .
drwxr-xr-x 5 root root   4096 Oct 18 11:06 ..
alice@srv-entreprise:~$ sudo chmod 770 /srv/compta /srv/rh
```

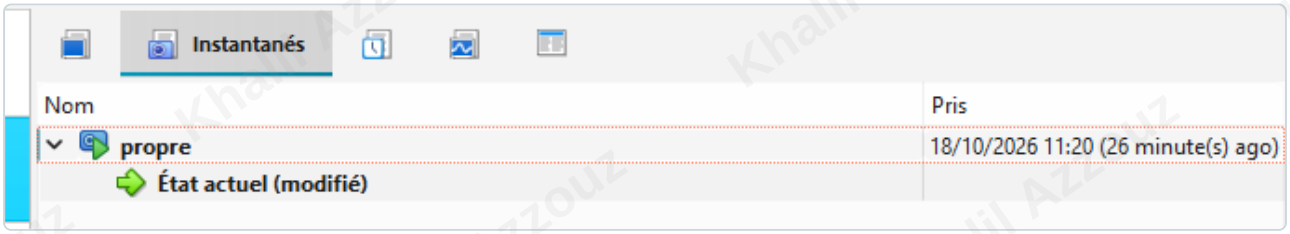
Création et attribution des dossiers de service.

```
alice@srv-entreprise:~$ ls -ld /srv/compta /srv/rh
drwxrwx--- 2 root compta 4096 Oct 18 11:06 /srv/compta
drwxrwx--- 2 root rh     4096 Oct 18 11:06 /srv/rh
alice@srv-entreprise:~$ getent passwd bob claire stagiaire
bob:x:1001:1001:bob,,,:/home/bob:/bin/bash
claire:x:1002:1002:claire,,,:/home/claire:/bin/bash
stagiaire:x:1003:1003:,,,:/home/stagiaire:/bin/bash
```

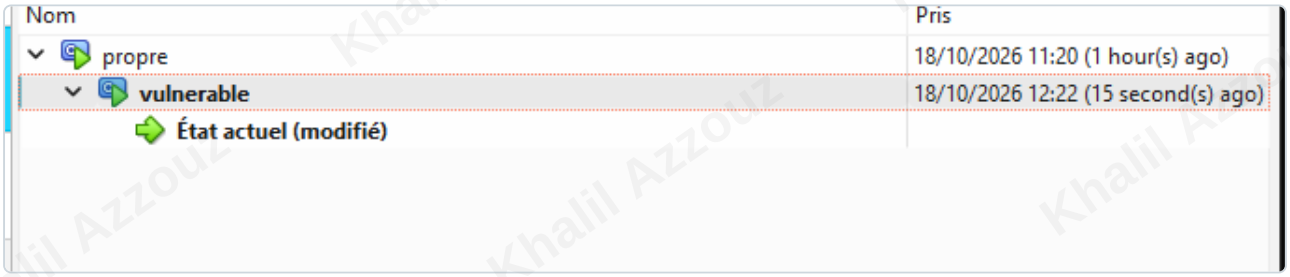
Résultat : drwxrwx---, accès limité au groupe du service.

9. Snapshots

Deux instantanés permettent de tester le futur script dans deux états et de revenir en arrière à tout moment : **propre** (serveur sain) et **vulnerable** (avec failles).



Snapshot « propre » pris après la configuration saine.



Arborescence des snapshots : propre, puis vulnerable.

10. Failles introduites volontairement

Pour vérifier que le script détecte de vrais problèmes, on affaiblit délibérément le serveur (automatisé dans `tests/vulnerable_setup.sh`).

#	Faille	Gravité	Commande
1	Compte caché UID 0	**Critique**	`useradd -o -u 0 -g 0 -M -s /bin/bash admin2`
2	Fichier world-writable	Moyen	`chmod 666 /srv/compta/budget.txt`
3	SSH root autorisé	**Critique**	`PermitRootLogin yes`
4	Pare-feu inactif	Moyen	`ufw disable`

11. Audit manuel sur l'état vulnérable

Les six contrôles lancés à la main sur l'état **vulnerable**. Les quatre failles apparaissent bien.

```
stat -c '%a %U:%G %n' /etc/passwd /etc/shadow
awk -F: '$3==0 {print $1}' /etc/passwd
sudo grep -i '^PermitRootLogin' /etc/ssh/sshd_config
sudo ufw status
ss -tuln
sudo find /srv -xdev -perm -0002 -type f
```

```
alice@srv-entreprise:~$ sudo useradd -o -u 0 -g 0 -M -s /bin/bash admin2
[sudo] password for alice:
useradd warning: admin2's uid 0 outside of the UID_MIN 1000 and UID_MAX 60000 range.
alice@srv-entreprise:~$ sudo touch /srv/compta/budget.txt
alice@srv-entreprise:~$ sudo chmod 666 /srv/compta/budget.txt
alice@srv-entreprise:~$ sudo sed -i 's/^#\?PermitRootLogin.*/PermitRootLogin yes/' /etc/ssh/sshd_config
[sudo] password for alice:
alice@srv-entreprise:~$ sudo systemctl restart ssh
```

Résultats de l'audit manuel : admin2 (UID 0), PermitRootLogin yes, pare-feu inactif, budget.txt world-writable.

> **Lecture des résultats.** `/etc/shadow` en 640 est **sain**. En revanche `admin2` en UID 0 et `PermitRootLogin yes` sont **critiques** ; le pare-feu inactif et le fichier en 666 sont de gravité moyenne.

12. Les contrôles du script et leur score

Le script part de 100 points et retire des points par faille : critique −20, moyen −10, faible −5. Un contrôle inapplicable (service absent) est marqué N/A.

#	Contrôle	Commande clé	Gravité
1	Droits /etc/passwd et /etc/shadow	`stat -c '%a' /etc/shadow`	**Critique**
2	Comptes UID 0	`awk -F: '$3==0'`	**Critique**
3	Configuration SSH	`grep PermitRootLogin`	**Crit. / Moyen**
4	Pare-feu	`ufw status`	Moyen
5	Ports ouverts	`ss -tuln`	Faible
6	Fichiers world-writable	`find / -perm -0002`	Moyen

13. Le script audit.sh

Le script est écrit en **Bash**, car ses contrôles sont déjà des commandes Linux (`stat`, `awk`, `grep`, `ss`, `find`) : Bash les enchaîne et décide « sain » ou « faille ». Aucune dépendance, il tourne sur tout serveur Linux, et reste en **lecture seule**.

Il s'appuie sur une fonction centrale `record()` qui, pour chaque contrôle, ajuste le score, affiche une ligne colorée alignée et stocke une ligne du rapport Markdown. Chaque contrôle est une fonction séparée, appelée dans l'ordre par `main()`.

```
record() {
    local statut="$1" gravite="$2" titre="$3" detail="$4"
    if [[ "$statut" == "FAIL" ]]; then
        case "$gravite" in
            critique) SCORE=$((SCORE - 20)) ;;
            moyen)    SCORE=$((SCORE - 10)) ;;
            faible)   SCORE=$((SCORE - 5))  ;;
        esac
    fi
    printf '  %-6s %-9s %s\n' "$statut" "$gravite" "$titre"
    ROWS+=("| $statut | $gravite | $titre | $detail |")
}
```

Qualité : le script passe **ShellCheck** (le linter de référence pour Bash) sans aucun avertissement.



Le script audit.sh dans l'éditeur : une fonction par contrôle.

```
alice@srv-entreprise:~$ shellcheck audit.sh
alice@srv-entreprise:~$ shellcheck audit.sh
alice@srv-entreprise:~$ shellcheck audit.sh
```

ShellCheck ne renvoie aucun avertissement (sortie vide = code propre).

L'explication détaillée du code, bloc par bloc, est dans `docs/script-explained.md`.

14. Résultats : vulnerable vs propre

Le même script, lancé sur les deux snapshots, distingue bien un serveur troué d'un serveur sain — c'est la preuve que l'outil fonctionne.



État vulnerable : score 50/100, les 4 failles détectées (admin2, SSH root, pare-feu, budget.txt).



État propre : score 100/100, tous les contrôles en PASS.

> **Prochaine étape.** Tester le script dans un conteneur Docker minimal : sans SSH ni pare-feu, les contrôles concernés doivent passer en `N/A` sans fausser le score — ce qui distingue un outil robuste d'un script fragile.